以 OpenClaw 為例看代理人架構資安



字級設定： 小 中 大 特

金管會發布金融業運用代理AI安全諮詢文件

2026/10/14 08:05 人氣(627)

MoneyDJ新聞 2026-10-14 08:05:27 陳怡潔 發佈

代理AI時代來臨，金管昨(13)日發布「金融業運用代理AI安全諮詢文件」，就金融業導入代理AI之安全治理、風險分級、安全控管等三大面向徵詢外界意見，要協助金融業安全導入代理AI，並為金融業資安設立防線。

金管會表示，近年人工智慧(AI)技術快速發展，其中代理AI相較於以生成回覆為主之聊天式AI，具備規劃步驟、呼叫工具、跨系統存取資料以推進任務之能力，金融業若能妥善運用代理AI，將有助於提升營運效率與推動服務創新；反之，若缺乏適當管理，可能導致目標偏離原始目的、工具誤用或越權、敏感資料外洩，或因多步流程造成錯誤連鎖擴大等效應。

金管會說明，為協助金融業安全導入代理AI，本文件經參考國際間安全框架，並本於風險導向、比例原則及技術中立立場，提出三大面向之諮詢重點如下：

一、 安全治理面：本文件第3章強調金融業導入代理AI時，宜以「應用場景」為管理單位，先釐清其業務目的、責任分工、可取用資料、可呼叫工具、可執行動作、輸出

https://www.moneydj.com/kmdj/news/newsviewer.aspx?a=a116731e-7986-4bd3-800c-c2b036fe84b0

- 文件定位：本文件為諮詢文件，旨在就金融機構導入代理 AI 之安全治理、風險分級、控 制原則及實務導入方向徵詢各界意見，所列內容作為後續政策研議與文件修訂之參考。本 文件不取代現行法令、監理規範、委外管理及金融機構既有內部控制要求。
- 適用範圍：本文件主要適用於可介接、操作、異動或觸發金融機構營運系統之代理 AI。僅 供個人辦公或開發輔助，且於使用者既有權限邊界內運作之個人 AI 助理，例如資訊整 理、內容草擬、會議摘要或程式碼建議等，得依既有內部控制及資安管理機制辦理，無須 逐項參考本文件。惟如其可自主呼叫工具、跨系統取用資料、對外傳送、寫入系統、觸發 正式作業流程，或其用途、資料、工具、權限、自動化程度與使用對象已有重大變更，仍 宜重新評估其是否屬本文件適用範圍，並依風險調整控管措施。

為了怕被拿去做文章，以摘要為主，不會在
投影片上加入個人意見

導入代理 AI 時，宜以下列原則作為共同基準

- 銜接既有內控：代理 AI 介接營運系統時，應以補強既有內控為原則，不得繞過原系 統既有授權、職務分工、交易檢核、紀錄留存、覆核及復原機制。
- 風險導向導入：依應用場景風險分級、系統可控性要求與自動化程度分階段導入，並 以風險分級決定上線門檻、覆核要求與監控強度。
- 循零信任原則：依應用場景風險管理代理身分與權限、執行環境、網路、工具及資料 取用，不因身分已驗證、連線已建立或工具可被呼叫，即推定後續行為可信；金融機 構宜採取可達成能力邊界管理、持續驗證、異常阻斷、停用、復原及回溯之控制，使 代理 AI 持續於核准邊界內運作。
- 保留人為控制：涉及不可逆、高影響或重大客戶權益之動作，宜依風險等級及既有法 令、內控與職務分工要求，保留人工確認或覆核，不宜僅由代理自動執行；並宜具備 降級、轉人工處理，以及必要之申訴、更正與模型風險管理機制。
- 確保可控可追溯：缺乏必要紀錄、無法停用、無法撤銷、無法復原或無法追溯者，不 宜正式自動化。
- 管理第三方與供應鏈風險：涉及第三方模型、平台、工具或服務者，宜納入既有委外 與供應鏈治理，依應用場景風險掌握責任分工、資料與工具邊界、變更與事件管理、 持續監控及退場安排。第三方提供之資訊或控制能力不足以支持風險管理者，宜採取相稱之補償控制或限縮使用範圍。

目前章節內容

- 一、代理 AI 運作特性
- 二、國際間對代理 AI 安全之因應
- 三、代理 AI 安全治理
- 四、代理 AI 風險分級
- 五、代理 AI 安全控管
- 六、結語

代理 AI 安全治理

- 責任分工
- 高階治理與董事會監督
- 應用場景列管
- 風險導向
- 安全護欄
- 監控與稽核
- 生命週期治理

代理 AI 風險分級

- 分級流程
- 分級定義 (示意：L1–L4)
- 正式上線基準與例外管理
- 分級運用與持續重評
  - 應用場景變更重評
    - 應用場景之資料來源、工具白名單、目的地、權限、自動化程 度、外送、寫入、批次、自動觸發或流程推進能力重大變更時，宜重新評估風險分級 與系統可控性。
  - 模型與工具版本變更
    - 底層模型、提示詞或關鍵工具重大更新時，宜依風險辦理回歸測試或等效驗證；L1 / L2 應用場景之微幅版本、提示詞或核准範圍內參照資料更新，且未擴大資料、工具或動作能力者，得以簡化紀錄辦理。
  - 代理漂移檢視
    - 金融機構宜定期檢視代理數量、版本、用途、責任人、權限、工具、 連接器、資料來源、提示與自動化流程，避免代理蔓延、重複建置、測試代理長期留 存、舊版代理未退場，或代理權限與工具設定逐步偏離原核准範圍。

等級	資料敏感度	動作影響	能力邊界 / 可擴散性
L1 (低)	公開資訊、一般非敏感內部資訊，或不含可識別個人與受保護金融資料之測試資料。	僅產生低影響輔助輸出，不形成正式紀錄、系統異動或流程推進效果。	任務單純、步驟有限，無跨客戶、跨系統或自動擴散能力。
L2 (中低)	一般內部資料、少量個資或低影響營運資料，且應用場景明確、影響對象有限。	產出查詢、摘要、彙整、草稿或預覽等輔助結果；如涉及內部流程，僅得由人員依既有程序採用或另行執行，不由代理直接形成正式紀錄、寫入系統、變更狀態或推進正式流程。	可含多步查詢或彙整，但任務範圍、查詢對象與輸出用途明確，不得自行擴大任務。
L3 (中高)	敏感資料、跨來源整合資料、較大量客戶或營運資料；或資料使用情境涉及客戶互動、法遵義務或較高營運影響。	可能產生受控外送、正式紀錄、正式工單、非核心系統異動或流程推進效果，且其業務情境、影響對象、可復原性或覆核要求顯示需較高控管者。	可多步、批次或跨系統執行，但宜受限於明確資料範圍、目的地、參數及最大影響範圍。
L4 (高)	高度敏感、高集中度或高價值資料，或資料使用情境可能對客戶權益、法遵義務或營運韌性造成重大影響者。	可能影響核心金融業務、核心或高重要性系統、交易或付款、額度或權限、不可逆或難以復原之處置、法遵最終處置、重大客戶權益或營運韌性。	具升權、委派、跨系統、批次、持續執行或高影響動作能力；錯誤或濫用可能迅速擴大影響。

代理 AI 安全控管 – 身分

- 基本控制措施：
  - 1-1 身分唯一識別
  - 1-2 身分與憑證分離使用
  - 1-3 任務授權邊界
  - 1-4 技能身分與授權承接
  - 1-5 委派關係管理
  - 1-6 代理退場與撤銷
  - 1-7 身分與授權紀錄
- 進階要求：
  - 1-8 憑證與密鑰強化管理
  - 1-9 權杖與身分聲明驗證
  - 1-10 任務型短期授權
  - 1-11 身分條件不足時之限制

系統可控性目標：

- 可觀測
- 可限制
- 可阻斷
- 可復原
- 可回溯

代理 AI 安全控管 —設備 / 執行環境

- 基本控制措施：
  - 2-1 執行環境分級與部署區隔
  - 2-2 執行環境基準與識別
  - 2-3 執行環境健康驗證
  - 2-4 執行環境異常中止與隔離
- 進階要求：
  - 2-5 執行環境隔離與資源邊界
  - 2-6 程式與指令執行限制
  - 2-7 執行環境資源限制
  - 2-8 執行環境動態條件
  - 2-9 環境復原與切換驗證
  - 2-10 執行環境條件不足時之限制

系統可控性目標：

- 可觀測
- 可限制
- 可阻斷
- 可復原
- 可回溯

代理 AI 安全控管 – 網路

- 基本控制措施：
  - 3-1 通訊邊界與路徑管制
  - 3-2 跨代理與跨系統訊息驗證
  - 3-3 異常通訊處置
- 進階要求：
  - 3-4 網路微分段
  - 3-5 高風險通訊安全
  - 3-6 高風險外送通道與傳輸限制
  - 3-7 網路條件不足時之限制

系統可控性目標：

- 可觀測
- 可限制
- 可阻斷
- 可復原
- 可回溯

代理 AI 安全控管 –應用與工作負載

- 基本控制措施：
  - 4-1 工具與介接清冊
  - 4-2 工具輸入輸出檢查
  - 4-3 營運系統安控銜接
- 進階要求：
  - 4-4 結構化介面強化
  - 4-5 第三方工具與元件治理
  - 4-6 技能載入控管
  - 4-7 應用與部署變更管理

系統可控性目標：

- 可觀測
- 可限制
- 可阻斷
- 可復原
- 可回溯

代理 AI 安全控管 –應用與工作負載

- 基本控制措施：
  - 5-1 資料取用與存取邊界
  - 5-2 記憶、脈絡與衍生資料治理
  - 5-3 RAG / 知識庫建置與運作
  - 5-4 外部資料與知識來源准入
- 進階要求：
  - 5-5 敏感資料與大量取用控管
  - 5-6 高風險資料使用與流向規則
  - 5-7 非標準介面之資料取用
  - 5-8 污染資料處理與回復
  - 5-9 資料條件不足時之限制

系統可控性目標：

- 可觀測
- 可限制
- 可阻斷
- 可復原
- 可回溯

代理 AI 安全控管 –行為控制

- 基本控制措施：
  - 6-1 行為邊界
  - 6-2 工具鏈與流程限制
  - 6-3 執行規模與持續性限制
  - 6-4 執行前行為查驗
- 進階要求：
  - 6-5 執行結果驗證與狀態確認
  - 6-6 規劃與執行分離
  - 6-7 高影響動作放行與覆核
  - 6-8 流程狀態與斷路器
  - 6-9 行為控制條件不足時之限制

系統可控性目標：

- 可觀測
- 可限制
- 可阻斷
- 可復原
- 可回溯

代理 AI 安全控管 – 可視性分析

- 基本控制措施：
  - 7-1 必要日誌與共同識別
  - 7-2 日誌保護與留存管理
  - 7-3 日誌關聯與事件流程銜接
- 進階要求：
  - 7-4 日誌與監控有效性
  - 7-5 行為基準與異常偵測
  - 7-6 異常處置與控制回饋

系統可控性目標：

- 可觀測
- 可限制
- 可阻斷
- 可復原
- 可回溯

大綱

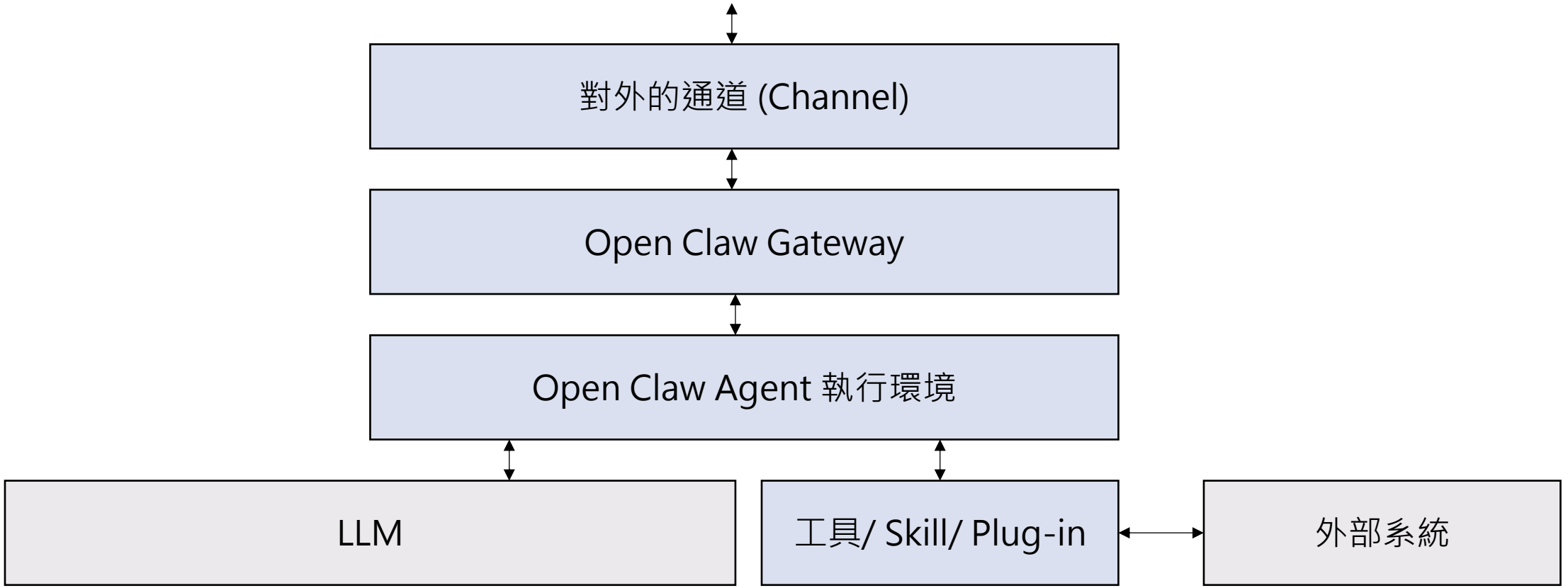
- OpenClaw 架構
- 由本地模型+高限制建立本地代理人應用
- 加入通道可以由 Line 控制
- 逐步放寬與安全風險
  - 工具的限制
  - Skill 的限制
  - Plugin 安全與控制
  - 存取控制機制的不足與限制
  - 執行環境的安全考量

- OpenClaw 架構
- 由本地模型+高限制建立本地代理人應用
- 加入通道可以由 Line 控制
- 逐步放寬與安全風險
  - 工具的限制
  - Skill 的限制
  - Plugin 安全與控制
  - 存取控制機制的不足與限制
  - 執行環境的安全考量

OpenClaw AI Agent 平台

- 源自奧地利開發者 Peter Steinberger 在 2025 年 11 月發布的 ClawBot
- 是一套可自行部署的開源 AI Agent 平台，讓 LLM 不只是產生文字，而能透過 Tools、Skills、Memory 與外部服務整合執行實際任務，並可透過 LINE、Telegram、Discord 等通訊介面與使用者互動。
- 具有以下的能力或特色：

能力	說明
Self-hosted	Agent Gateway 可部署於自己的電腦或伺服器
Multi-LLM	可連接 Claude、OpenAI、Gemini 或本地模型等
Tools / Skills	Agent 可操作檔案、Shell、Web、API 及各種外部工具
Memory & Sessions	保存對話、工作狀態與長期記憶，支援長時間 Agent 工作
Messaging Gateway	將 Agent 接到 LINE、Telegram、Discord 等通訊平台
Extensible	透過 Plugins / Skills / MCP 等方式擴充 Agent 能力


對外的通道 (Channel)
Open Claw Gateway
Open Claw Agent 執行環境
LLM
工具/ Skill/ Plug-in
外部系統

- OpenClaw 架構
- 由本地模型+高限制建立本地代理人應用
- 加入通道可以由 Line 控制
- 逐步放寬與安全風險
  - 工具的限制
  - Skill 的限制
  - 存取控制機制的不足與限制
  - 執行環境的安全考量

安裝前準備

- 建立工作目錄
  - 小語言模型目錄
  - OpenClaw 運作目錄
- 設定環境變數
  - 如果是要安裝 Ollama 的話，可以將OLLAMA_MODELS設定為小語言模型目錄
- 確認系統版本
  - OpenClaw 官方目前要求 Node.js 24.16+ 或 26.1+，並推薦 Node 26。若 Node 不符合，官方 Windows 安裝器可協助安裝支援版本。

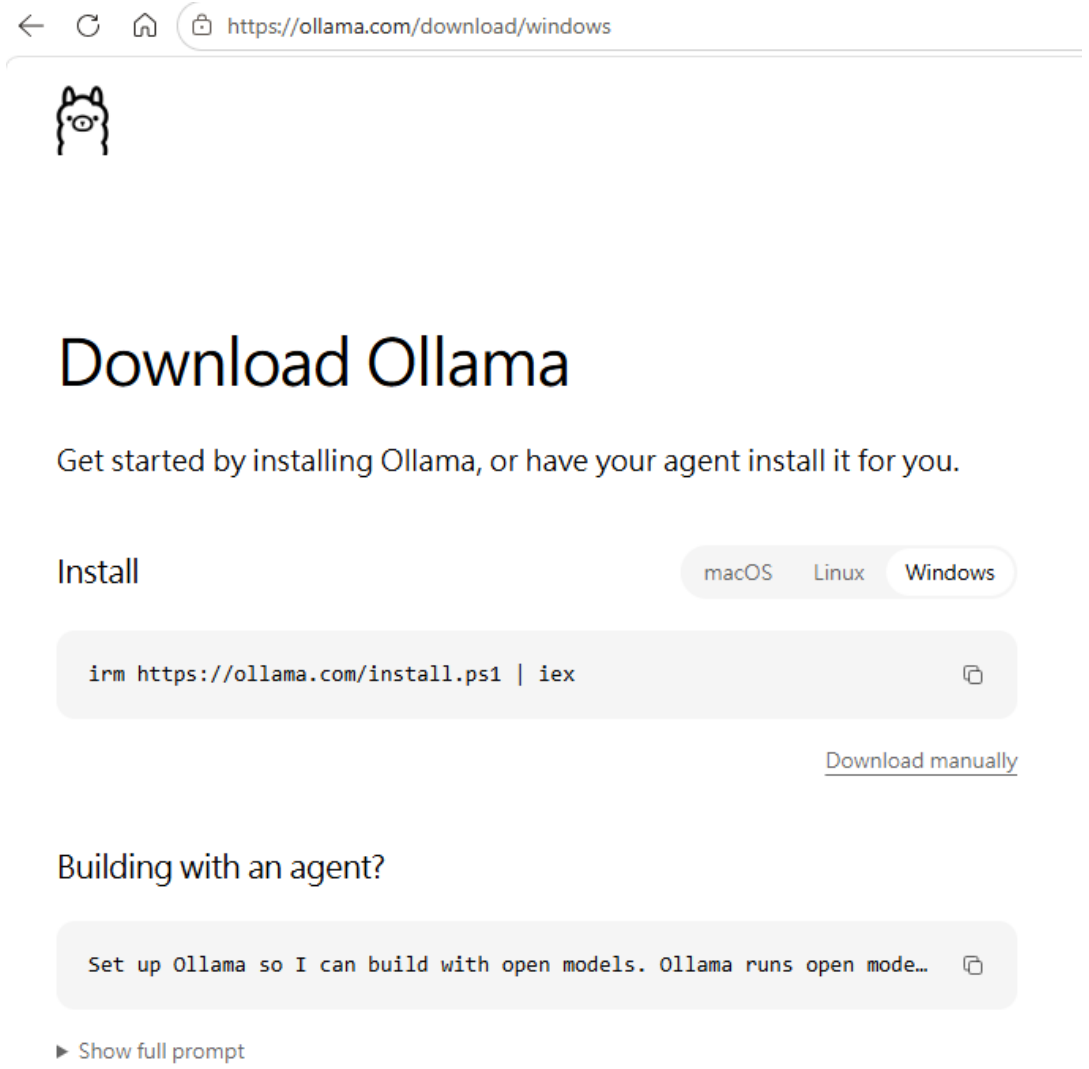
```
PS D:\work\code\localllm> docker version
 GitCommit:        05044ec0a9a75232cad458027ca83437aae3f4da
runc:
 Version:          1.2.5
 GitCommit:        v1.2.5-0-g59923ef
docker-init:
 Version:          0.19.0
 GitCommit:        de40ad0
PS D:\work\code\localllm> node --version
v24.21.0
PS D:\work\code\localllm> npm --version
11.19.0
PS D:\work\code\localllm> nvidia-smi
Mon Oct  5 00:05:07 2026
+-----------------------------------------------------------------------------------------+
| NVIDIA-SMI 591.86                 Driver Version: 591.86         CUDA Version: 13.1     |
+-----------------------------------------+------------------------+----------------------+
| GPU  Name                  Driver-Model | Bus-Id          Disp.A | Volatile Uncorr. ECC |
| Fan  Temp   Perf           Pwr:Usage/Cap |           Memory-Usage | GPU-Util  Compute M. |
|                                         |                        |               MIG M. |
|=========================================+========================+======================|
|   0  NVIDIA GeForce RTX 4060      WDDM  |   00000000:01:00.0 Off |                  N/A |
|  0%   37C    P5             N/A  /  115W |     762MiB /   8188MiB |      0%      Default |
|                                         |                        |                  N/A |
+-----------------------------------------+------------------------+----------------------+
```

安裝 Ollama

- irm https://ollama.com/install.ps1 | iex

```
PS D:\work\code\localllm> irm https://ollama.com/install.ps1 | iex
>>> Downloading Ollama for Windows...
######################################## 100.0%
>>> Installing Ollama...
>>> Install complete. Run 'ollama' from the command line.
```

```
PS D:\work\code\localllm> ollama --version
>> ollama list
ollama version is 0.35.1
NAME    ID    SIZE    MODIFIED
```



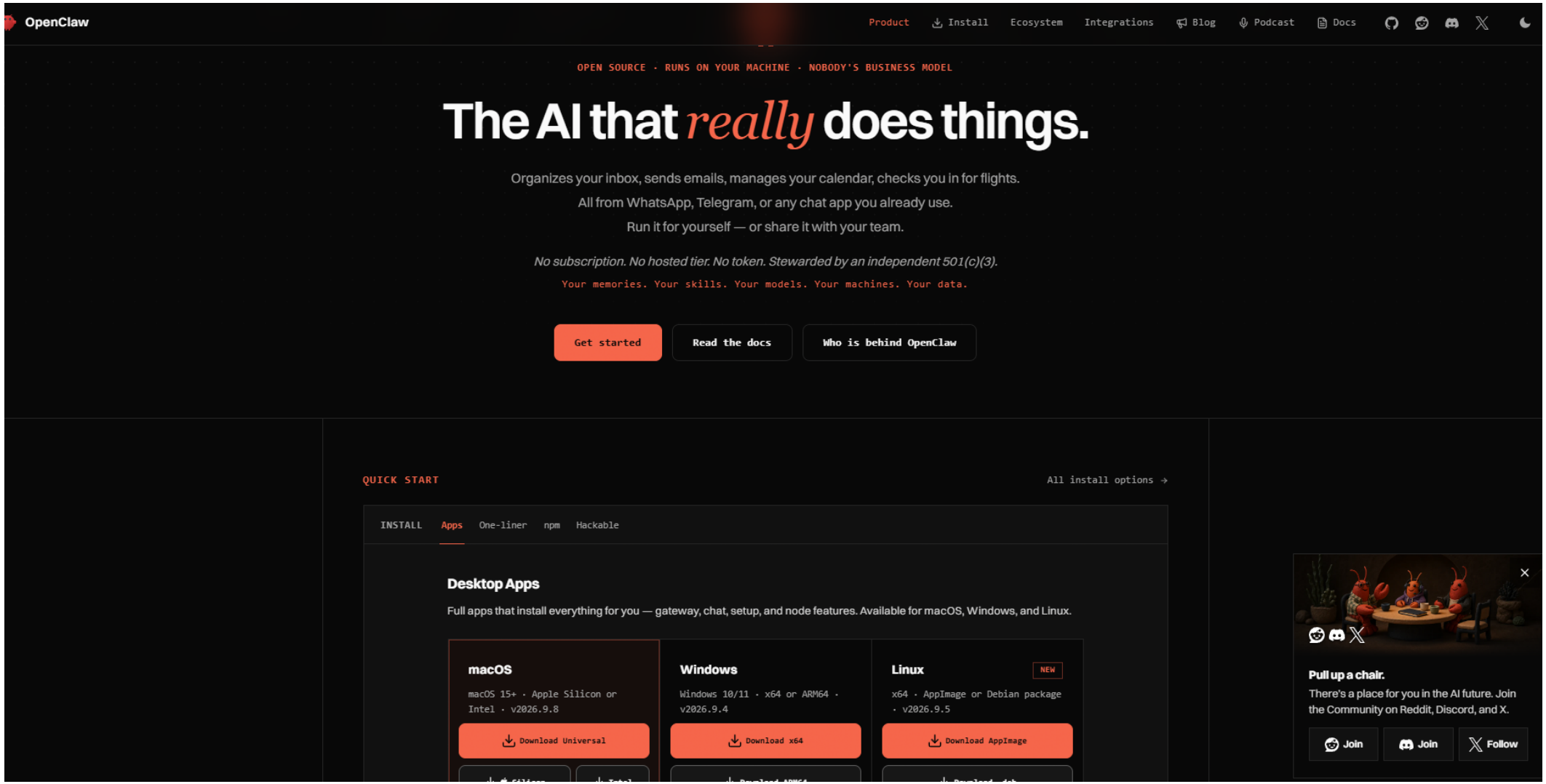
安裝模型

- 如果要安裝 Ministral 3 8B
  - ollama pull ministral-3:8b
  - ollama run ministral-3:8b

```
PS D:\work\code\localllm> ollama pull ministral-3:8b
pulling manifest
pulling 3ea32f882c99: 100%                                                  6.0 GB
pulling e0daf17ff83e: 100%                                                   21 B
verifying sha256 digest
writing manifest
success
PS D:\work\code\localllm> ollama run ministral-3:8b
>>> /?
Available Commands:
  /set            Set session variables
  /show           Show model information
  /load <model>   Load a session or model
  /save <model>   Save your current session
  /clear          Clear session context
  /bye            Exit
  /?, /help       Help for a command
  /? shortcuts    Help for keyboard shortcuts

Use """ to begin a multi-line message.
Use \path\to\file to include .jpg, .png, .webp images, or .wav audio files.
```

下載 OpenClaw


OpenClaw
Product
Install
Ecosystem
Integrations
Blog
Podcast
Docs
OPEN SOURCE · RUNS ON YOUR MACHINE · NOBODY'S BUSINESS MODEL
The AI that really does things.
Organizes your inbox, sends emails, manages your calendar, checks you in for flights.
All from WhatsApp, Telegram, or any chat app you already use.
Run it for yourself — or share it with your team.
No subscription. No hosted tier. No token. Stewarded by an independent 501(c)(3).
Your memories. Your skills. Your models. Your machines. Your data.
Get started
Read the docs
Who is behind OpenClaw
QUICK START
All install options →
INSTALL
Apps
One-liner
npm
Hackable
Desktop Apps
Full apps that install everything for you — gateway, chat, setup, and node features. Available for macOS, Windows, and Linux.
macOS
macOS 15+ · Apple Silicon or Intel · v2026.9.8
Download Universal
Windows
Windows 10/11 · x64 or ARM64 · v2026.9.4
Download x64
Linux
NEW
x64 · AppImage or Debian package · v2026.9.5
Download AppImage
Pull up a chair.
There's a place for you in the AI future. Join the Community on Reddit, Discord, and X.
Join
Join
Follow

- 使用 npm 安裝：
  - npm install -g openclaw@latest --allow-scripts=openclaw

全域　　信任下載的 npm 套件能夠以使用者身分執行程式

```
PS D:\work\code\localllm> npm install -g openclaw@latest --allow-scripts=openclaw
npm warn deprecated node-domexception@1.0.0: Use your platform's native DOMException instead

added 343 packages in 52s

112 packages are looking for funding
  run `npm fund` for details
npm warn install-scripts 4 packages have install scripts not yet covered by allowScripts:
npm warn install-scripts   @google/genai@2.23.0 (preinstall: echo 'preinstall: no-op')
npm warn install-scripts   esbuild@0.28.2 (postinstall: node install.js)
npm warn install-scripts   koffi@3.3.1 (install: node ./cnoke.cjs -P . -D src/koffi --prebuild --release)
npm warn install-scripts   protobufjs@7.6.6 (postinstall: node scripts/postinstall)
npm warn install-scripts
npm warn install-scripts Run `npm install -g --allow-scripts=@google/genai,esbuild,koffi,protobufjs` to allow these scripts once, or `npm config set
 allow-scripts=@google/genai,esbuild,koffi,protobufjs --location=user` to allow them for all global installs.
npm notice
npm notice New major version of npm available! 11.19.0 -> 12.2.0
npm notice Changelog: https://github.com/npm/cli/releases/tag/v12.2.0
npm notice To update run: npm install -g npm@12.2.0
npm notice
PS D:\work\code\localllm> where.exe openclaw
C:\Users\user\scoop\apps\nodejs-lts\current\bin\openclaw
C:\Users\user\scoop\apps\nodejs-lts\current\bin\openclaw.cmd
PS D:\work\code\localllm> openclaw --version
OpenClaw 2026.9.8 (fc23bc8)
```

先進行設定

- ollama launch openclaw --model ministral-3:8b

```
PS D:\work\code\localllm> ollama launch openclaw --config --model ministral-3:8b

Security

  OpenClaw can read files and run actions when tools are enabled.
  A bad prompt can trick it into doing unsafe things.

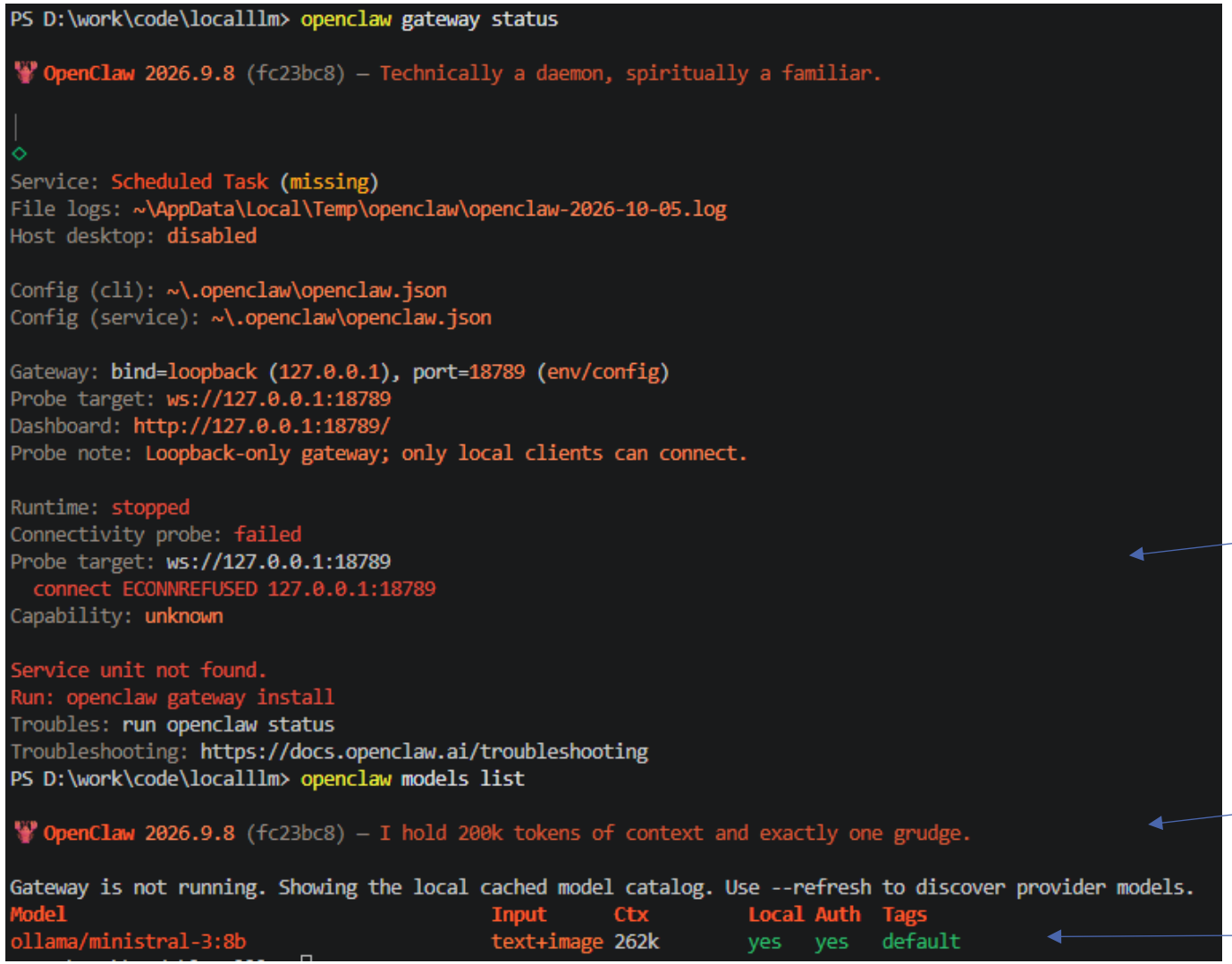
  Learn more: https://docs.openclaw.ai/gateway/security

◇
Phase: requested
Phase: staging
Phase: validating

Updating plugins...
No plugin updates needed.
Gateway restart skipped: no Gateway service or listener is running.
Phase: finished

OpenClaw update skipped: already-current.
Report: C:\Users\user\.openclaw\update-reports\7539fea5-5ff5-477a-99f3-dc3158062d2a.md
```

剛開始 Gateway 沒啟動



Gateway 設定

版本

使用模型與圖形支援

先做安全性設定

- 備份目前設定
  - Copy-Item `
    "$env:USERPROFILE\.openclaw\openclaw.json" `
    "$env:USERPROFILE\.openclaw\openclaw.json.pre-safe-start.bak "
- 固定 Gateway 為本機限定

  openclaw config set gateway.mode local
  openclaw config set gateway.bind loopback
  openclaw config set gateway.port 18789 --strict-json
  openclaw config set gateway.tailscale.mode off
  openclaw config set gateway.terminal.enabled false --strict-json

只聽本地的 loopback 介面

指令必須格式正確

不允許公開Gateway

不允許使用終端機執行額外工作

- 設定工作區

  openclaw config set agents.defaults.workspace "<.....> "
  openclaw config set tools.fs.workspaceOnly true --strict-json

先做安全性設定 (續)

- 使用唯讀工具政策

  openclaw config set tools.deny `
  '["exec","process","write","edit","apply_patch","b
  rowser","web_fetch","web_search","nodes","cron
  ","gateway"]' ` --strict-json

- 檢查憑證狀態

  openclaw config get gateway.auth.mode

```
PS D:\work\code\localllm> openclaw config get gateway.auth.mode
token
```

可聊天和測試模型，但不能：

- 執行 PowerShell或其他程式
- 修改或刪除檔案
- 操作瀏覽器
- 讀取不可信網頁
- 建立排程
- 操作 Gateway 本身

```
PS D:\work\code\localllm> openclaw configure --section gateway

◇  Where will the Gateway run?
   Local (this machine)

◇  Gateway port
   18789

◇  Gateway bind mode
   Loopback (Local only)

◇  Gateway access protection
   Token (recommended)

◇  Tailscale exposure
   Off

◇  Gateway token source
   Generate/store plaintext token

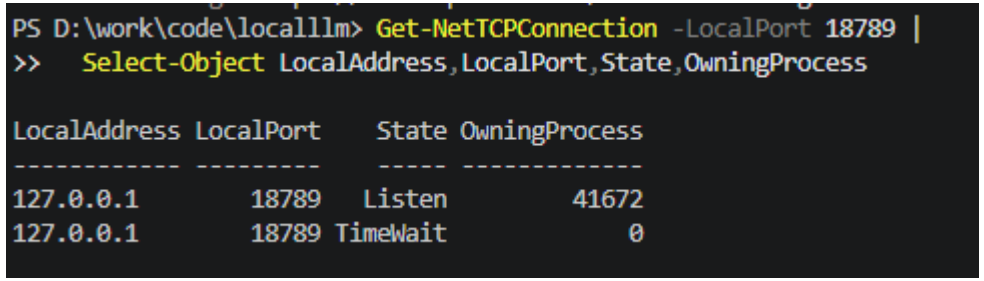
◇  Gateway token (blank to generate)

Updated config: ~\.openclaw\openclaw.json
  Backup: ~\.openclaw\openclaw.json.bak

◇  Control UI ──────────────
```

先做安全性設定 (續)

- 驗證設定
  - openclaw config validate
  - openclaw doctor
- 安裝並啟動 Windows 背景服務
  - openclaw gateway install
  - openclaw gateway start
  - openclaw gateway status
- 確認只有本機監聽
  - Get-NetTCPConnection -LocalPort 18789 | Select-Object LocalAddress,LocalPort,State,OwningProcess



可以看一下 Gateway 狀態

```
PS D:\work\code\localllm> openclaw gateway status

🦞 OpenClaw 2026.9.8 (fc23bc8) — I've seen your commit messages. We'll work on that together.

◇
Service: Scheduled Task (registered)
File logs: ~\AppData\Local\Temp\openclaw\openclaw-2026-10-05.log
Command: C:\Users\user\scoop\apps\nodejs-lts\current\node.exe --max-old-space-size=32689 C:\Users\user\scoop\persist\nodejs-lts\bin\node_modules\ope
nclaw\dist\index.js gateway --port 18789
Service file: ~\.openclaw\gateway.cmd
Service env: OPENCLAW_GATEWAY_PORT=18789
Gateway heap: service argv: --max-old-space-size=32689; installer recommendation: 32689 MiB old space (130758 MiB physical capacity; adaptive cap 32
689 MiB; native headroom cap 98068 MiB); runtime V8 ceiling: not measured
Host desktop: disabled

Config (cli): ~\.openclaw\openclaw.json
Config (service): ~\.openclaw\openclaw.json

Gateway: bind=loopback (127.0.0.1), port=18789 (service args)
Probe target: ws://127.0.0.1:18789
Dashboard: http://127.0.0.1:18789/
Probe note: Loopback-only gateway; only local clients can connect.

CLI version: 2026.9.8 (~\scoop\apps\nodejs-lts\current\bin\node_modules\openclaw\openclaw.mjs)
Gateway version: 2026.9.8

Runtime: running (pid 41672, last run 267009, last run time 2026-10-05T02:23:18.0000000Z, Gateway process detected for gateway port 18789.)
Connectivity probe: ok
Capability: connected-no-operator-scope

Listening: 127.0.0.1:18789
Troubles: run openclaw status
Troubleshooting: https://docs.openclaw.ai/troubleshooting
```

確認模型

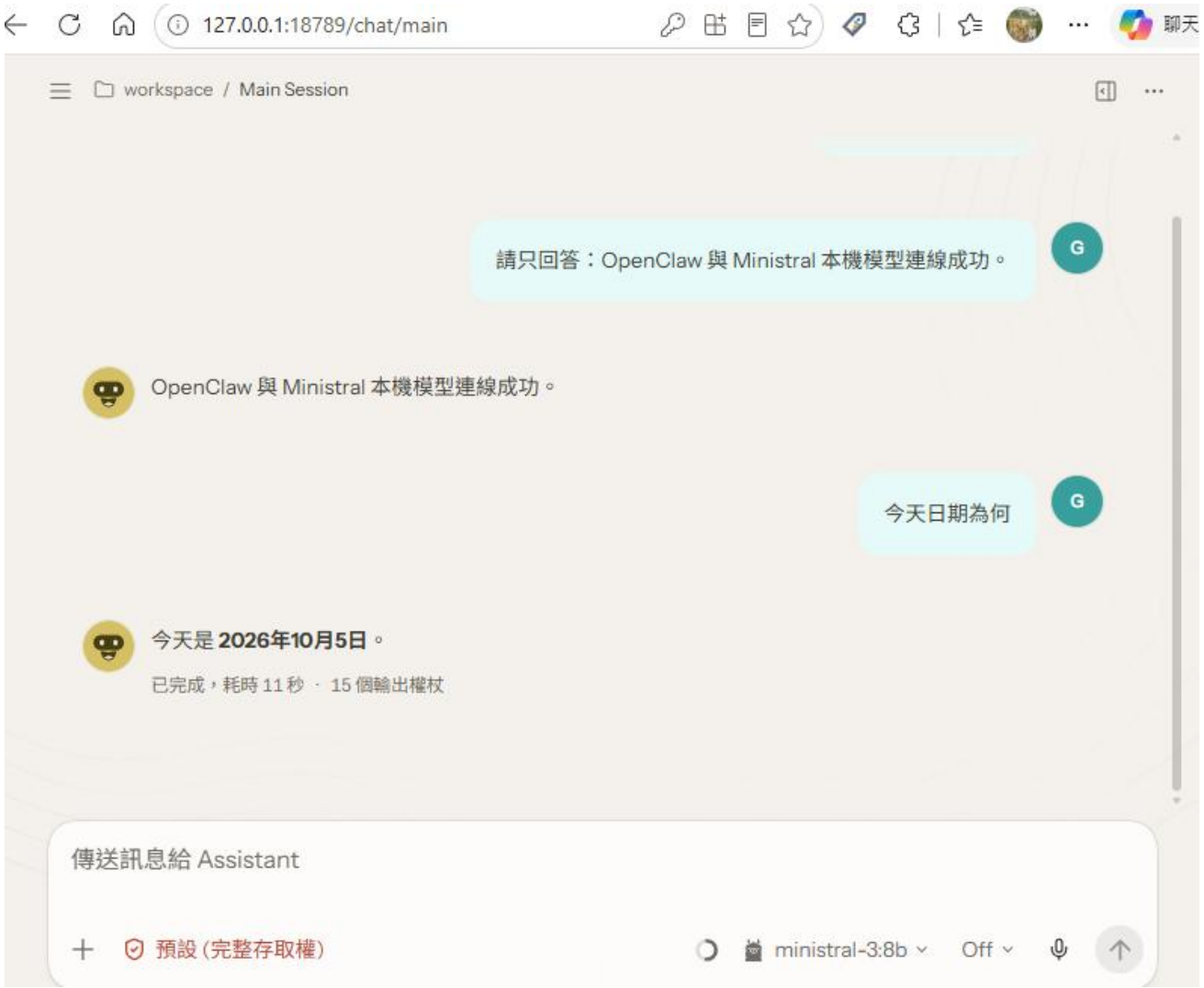
```
PS D:\work\code\localllm> openclaw models list

🦞 OpenClaw 2026.9.8 (fc23bc8) — I schedule my existential crises with cron so they never block your messages.

Model                                      Input      Ctx         Local Auth  Tags
ollama/ministral-3:8b                      text+image 262k        yes   yes   default
openai/gpt-6-astra                         text+image 272k/1050k  no    yes
openai/gpt-6.1-sol                         text+image 272k/1050k  no    yes
openai/gpt-6-sol                           text+image 272k/1050k  no    yes
openai/gpt-6-luna                          text+image 272k/1050k  no    yes
openai/gpt-5.6-sol                         text+image 272k/1050k  no    yes
openai/gpt-5.6-terra                       text+image 272k/1050k  no    yes
openai/gpt-5.6-luna                        text+image 272k/1050k  no    yes
openai/gpt-5.5                             text+image 272k/1050k  no    yes
openai/gpt-5.5-pro                         text+image 272k/1050k  no    yes
openai/gpt-5.4                             text+image 1050k       no    yes
openai/gpt-5.4-pro                         text+image 1050k       no    yes
openai/gpt-5.4-mini                        text+image 400k        no    yes
openai/gpt-5.4-nano                        text+image 400k        no    yes
openai/chat-latest                         text+image 400k        no    yes
PS D:\work\code\localllm> openclaw config get agents.defaults.model.primary
ollama/ministral-3:8b
PS D:\work\code\localllm> openclaw config get tools.deny --json
{
  "ok": false,
  "error": {
    "type": "cli_error",
    "message": "Config path is valid but unset: tools.deny. The runtime default applies until you set an authored value with openclaw config set too
ls.deny <value>."
  }
}
```

可以連接 Gateway 來確認

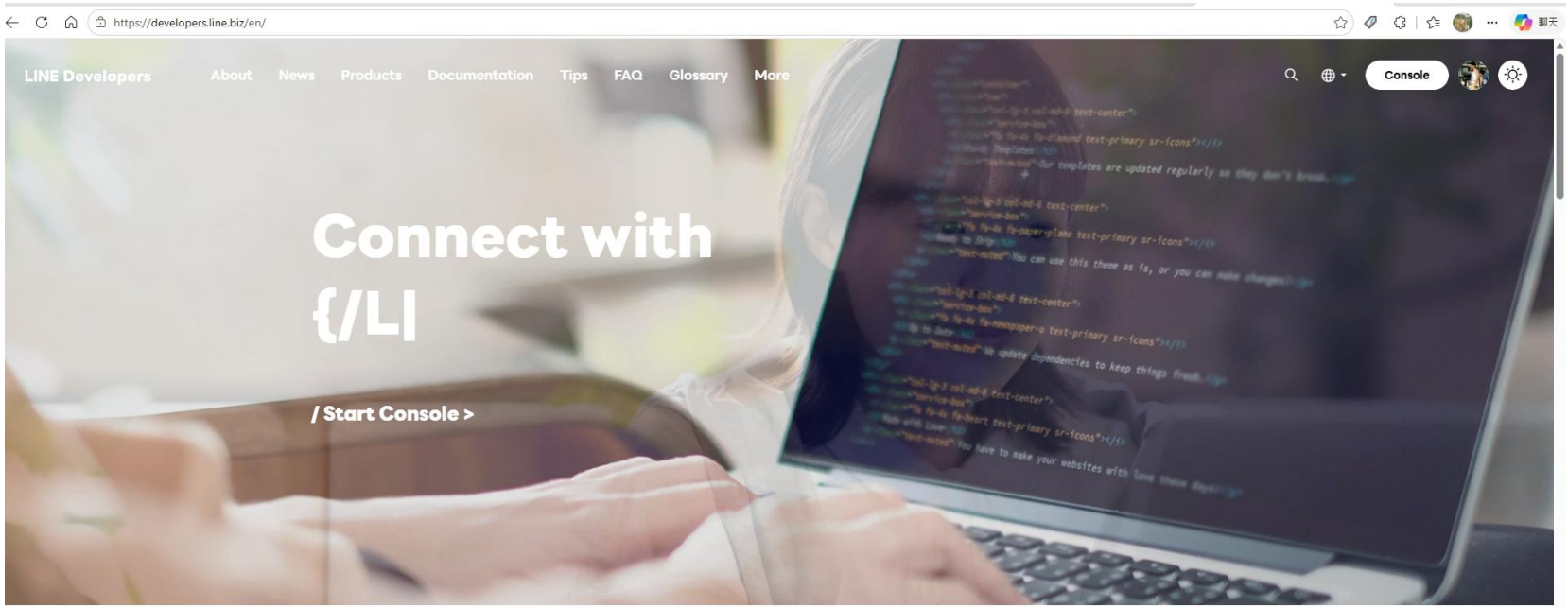



127.0.0.1:18789/chat/main
聊天
workspace / Main Session
請只回答：OpenClaw 與 Ministral 本機模型連線成功。
G
OpenClaw 與 Ministral 本機模型連線成功。
今天日期為何
G
今天是 2026年10月5日。
已完成，耗時 11 秒 · 15 個輸出權杖
傳送訊息給 Assistant
預設 (完整存取權)
ministral-3:8b
Off

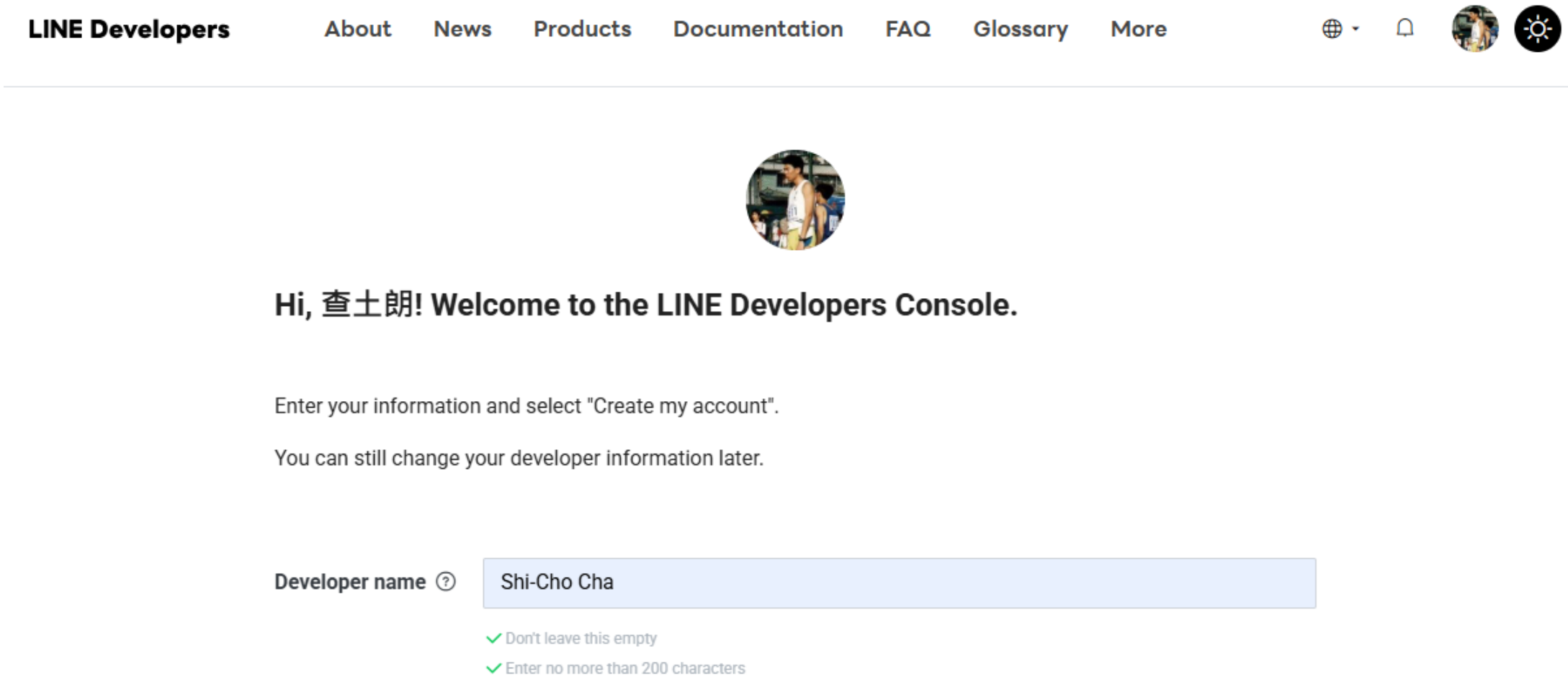
- OpenClaw 架構
- 由本地模型+高限制建立本地代理人應用
- 加入通道可以由 Line 控制
- 逐步放寬與安全風險
  - 工具的限制
  - Skill 的限制
  - Plugin 安全與控制
  - 存取控制機制的不足與限制
  - 執行環境的安全考量

連接 Line

- 安裝 Plugin
  - openclaw plugins install @openclaw/line
  - openclaw plugins list



登入開發者


LINE Developers
About
News
Products
Documentation
FAQ
Glossary
More
Hi, 查士朗! Welcome to the LINE Developers Console.
Enter your information and select "Create my account".
You can still change your developer information later.
Developer name
Shi-Cho Cha
Don't leave this empty
Enter no more than 200 characters

新增 Provider

TOP

Welcome to the LINE Developers Console!

Here, you'll find information and tools for connecting your technology to the LINE Platform, helping you build apps that connect people.

To get started, create a provider to represent your company, yourself, or another entity that provides the apps and services you're working on.



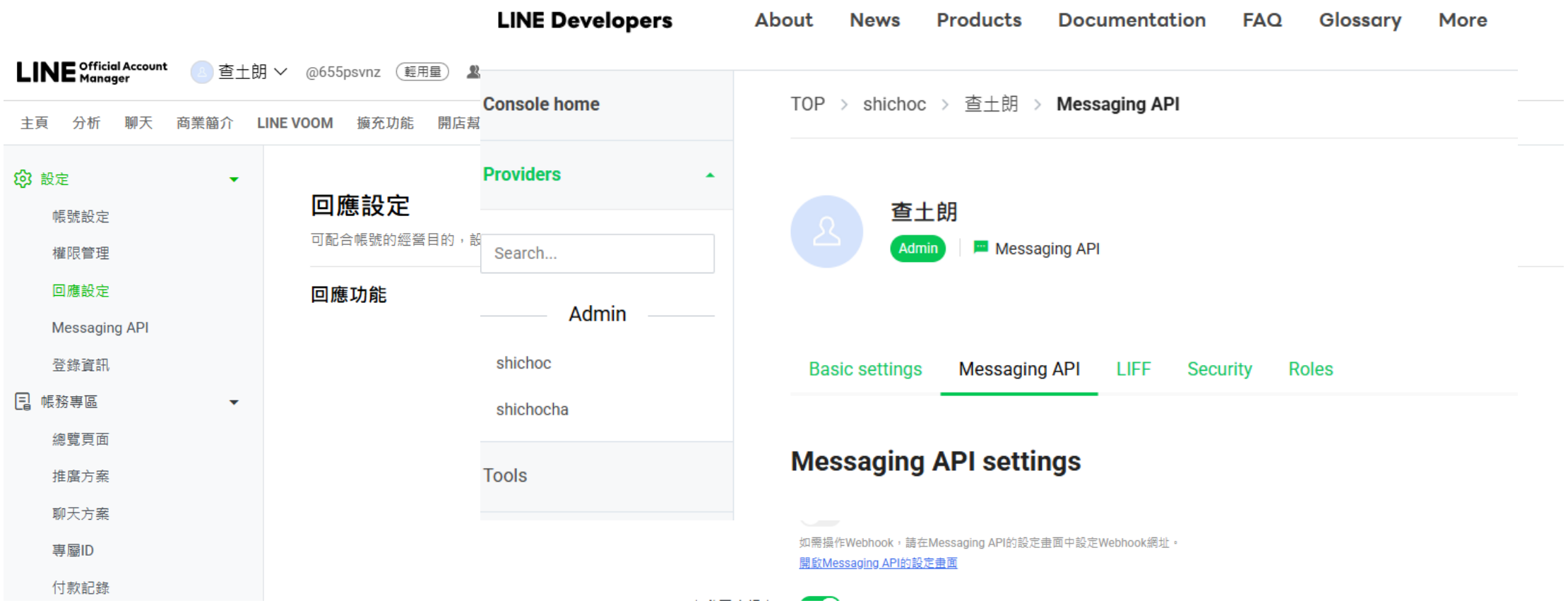
Start by creating a provider

Then, create a channel for each app you want to connect to the LINE Platform

Lastly, enter the necessary information to link your apps to your channels, and start building!

Create a new provider

設定 Messaging API (含 Official Account)



安全保存 LINE 憑證

- 建立目錄：
  - $lineSecretDir = "$env:USERPROFILE\.openclaw\secrets"
  - New-Item -ItemType Directory -Force -Path $lineSecretDir
- 使用文字編輯器分別建立兩個檔案：
  - notepad "$env:USERPROFILE\.openclaw\secrets\line-token.txt"
  - notepad "$env:USERPROFILE\.openclaw\secrets\line-secret.txt"
- 限制目錄只讓目前帳號存取：
  - icacls "$env:USERPROFILE\.openclaw\secrets" /inheritance:r
  - icacls "$env:USERPROFILE\.openclaw\secrets" /grant:r "$($env:USERNAME):(OI)(CI)F"

設定 LINE Channel

- openclaw config set channels.line.enabled true --strict-json
- openclaw config set channels.line.tokenFile "$env:USERPROFILE\.openclaw\secrets\line-token.txt"
- openclaw config set channels.line.secretFile "$env:USERPROFILE\.openclaw\secrets\line-secret.txt"
- openclaw config set channels.line.dmPolicy pairing
- openclaw config set channels.line.groupPolicy disabled
- openclaw config set channels.line.streaming.block.enabled false --strict-json

- `enabled=true`：啟用 LINE plugin。
- `tokenFile` / `secretFile`：從權限受限的檔案載入秘密。
- `dmPolicy=pairing`：陌生使用者必須先取得 pairing code，再由本機管理者核准。
- `groupPolicy=disabled`：完全忽略 LINE 群組及多人聊天室。
- `streaming.block.enabled=false`：等待完整回答後再回覆，避免一段回答消耗多則 LINE 訊息額度。

建立只公開 webhook 的 HTTPS Tunnel

- 安裝 cloudflared
  - scoop update
  - scoop install cloudflared
  - cloudflared --version
  - where.exe cloudflared
- 建立臨時測試 Tunnel
  - cloudflared tunnel --url http://127.0.0.1:18789

在 LINE Console 設定 Webhook

- 將 Webhook URL 設為：
  - https://line-bot.example.com/line/webhook
- 按下 Verify
- 驗證成功後開啟 Use webhook
- 建議開啟 Webhook redelivery
- 到 LINE Official Account Manager 關閉預設的 Greeting message 及 Auto-response message，避免同一則訊息收到兩次回覆。

- OpenClaw plugin 會使用 Channel secret，以原始 request body 做 HMAC-SHA256 驗證。不要在 OpenClaw 前方加入會修改 request body 的 middleware。

回應設定

可配合帳號的經營目的，設定聊天及自動訊息的回應方式。

回應功能

聊天

可透過聊天與好友互動。

加入好友的歡迎訊息

當用戶將本帳號加為好友時，可自動傳送訊息內容。

開啟「加入好友的歡迎訊息」設定畫面

Webhook

當用戶傳送訊息給本帳號或將本帳號加為好友時，從LINE平台傳送Webhook事件至Webhook網址。

開啟Messaging API的設定畫面

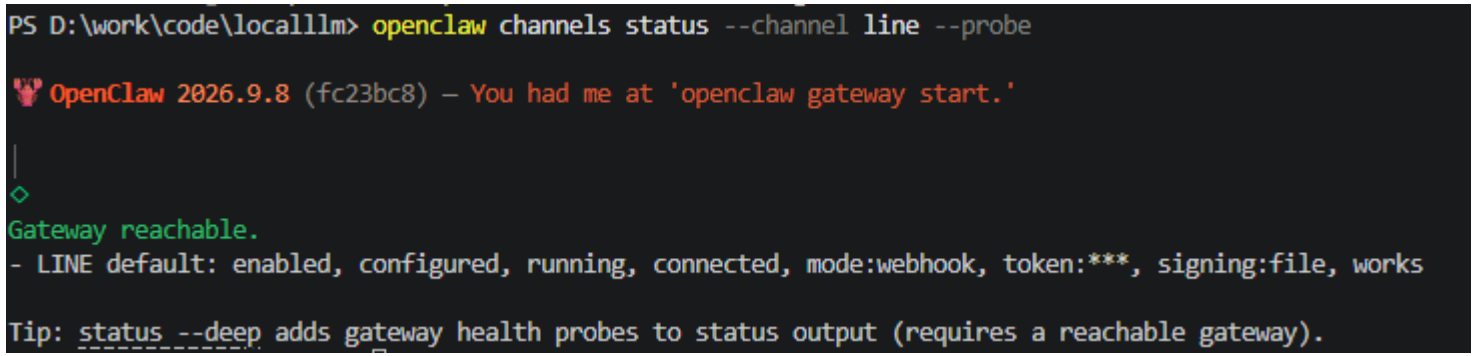
自動回應訊息

可使用事先設定好的訊息內容進行自動回覆。

開啟自動回應訊息的設定畫面

重啟並檢查 Channel

- openclaw gateway restart
- openclaw gateway status
- openclaw channels status --channel line --probe



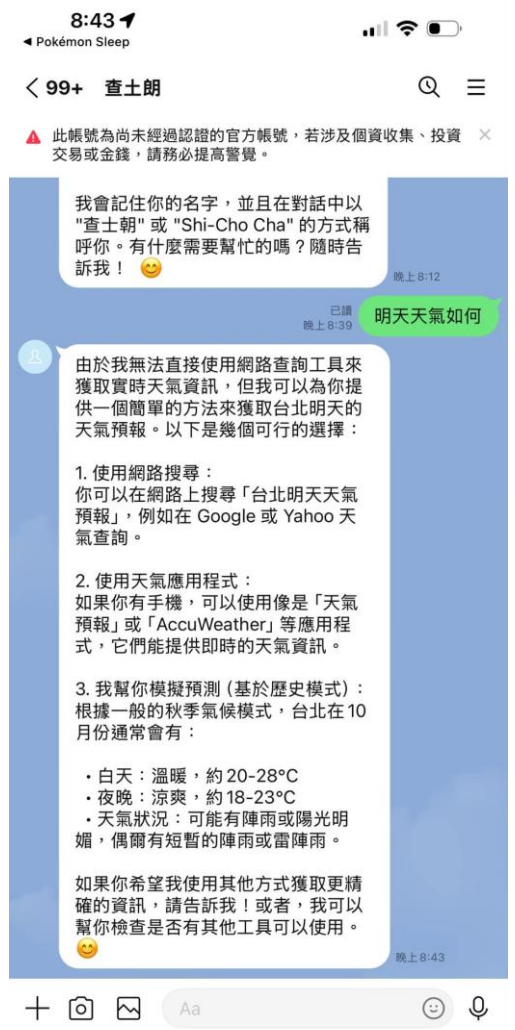
完成配對

- openclaw pairing list line
- openclaw pairing approve line <CODE>

```
PS D:\work\code\localllm> ollama ps
NAME              ID              SIZE     PROCESSOR          CONTEXT    UNTIL
ministral-3:8b    1922accd5827    43 GB    87%/13% CPU/GPU    262144     About a minute from now
```

現在不允許執行網路工具





- OpenClaw 架構
- 由本地模型+高限制建立本地代理人應用
- 加入通道可以由 Line 控制
- 逐步放寬與安全風險
  - 工具的限制
  - Skill 的限制
  - Plugin 安全與控制
  - 存取控制機制的不足與限制
  - 執行環境的安全考量

單純本地連線與開放 Line 連線的新增風險

如何控制？
- 防火牆
- 存取控制
- 護欄
- 通訊安全

目前僅限 loopback

風險面向	純本機連線	經由 LINE
Gateway 可達性	只有 127.0.0.1	Webhook 必須能從網際網路抵達
使用者身分	能操作本機帳號的人	LINE 使用者、群組成員或遭入侵的 LINE 帳號
訊息內容	通常由自己輸入	可能收到惡意文字、圖片、檔案或連結
資料隱私	大部分留在電腦	訊息與回覆會經過 LINE 平台
鑑別資訊	Gateway token	額外增加 LINE access token、channel secret、Tunnel 憑證
可用性	本機資源可控	公開 webhook 可能被掃描或大量請求

要限制僅提供 Webhook 的端點
因為有要經過配對，不是那麼容易可連

那模型呢？

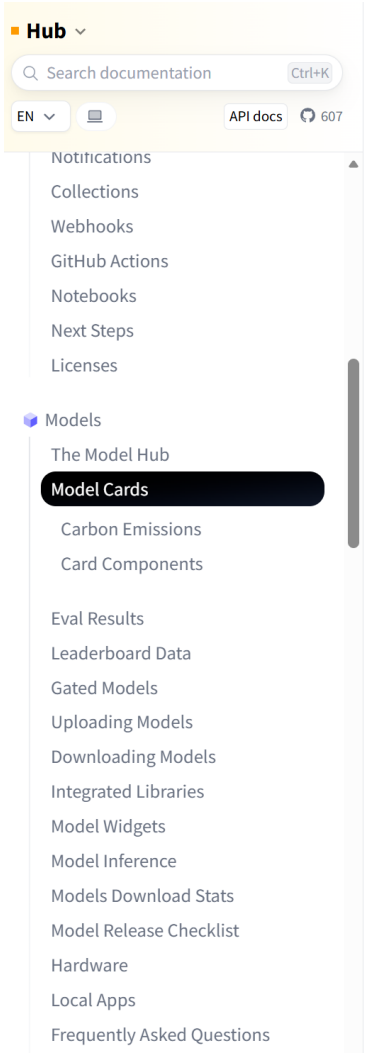
- 更換本地模型會有安全風險嗎？
- 本地模型會造成哪些安全風險？
  - 正確性或資料錯誤
  - 偏誤或歧視
  - 延遲或效能問題
- 有沒有可能對外自動攻擊
  - 單純模型可能會須要透過影響工具才能發動攻擊
  - 目前有可能有被包成一整包的本地模型應用，應用程式可能發動攻擊
- 本地 LLM 執行環境 (Local LLM Runtime) 的安全性也需要考量
  - 例如使用 Ollama 或 LMStudio，如何防護其安全性

- 那雲端模型呢？

如何控制？

- 建立模型審查程序
- 紀錄與監控模型的輸出
- 護欄
- 加強執行環境的安全性

一般模型的檢視可以考慮 Model Card



Model Cards

Copy page

What are Model Cards?

Model cards are files that accompany the models and provide handy information. Under the hood, model cards are simple Markdown files with additional metadata. Model cards are essential for discoverability, reproducibility, and sharing! You can find a model card as the `README.md` file in any model repo.

The model card should describe:

- the model
- its intended uses & potential limitations, including biases and ethical considerations as detailed in Mitchell, 2018
- the training params and experimental info (you can embed or link to an experiment tracking platform for reference)
- which datasets were used to train your model
- the model's evaluation results

The model card template is available here.

How to fill out each section of the model card is described in the Annotated Model Card.

Model Cards on the Hub have two key parts, with overlapping information:

- Metadata
- Text descriptions

Model card metadata

A model repo will render its `README.md` as a model card. The model card is a Markdown file, with a YAML section at the top that

Model Cards
What are Model Cards?
Model card metadata
Adding metadata to your model card
Using the metadata UI
Editing the YAML section of the README.md file
Specifying a library
Specifying a base model
Specifying a new version
Specifying a dataset
Specifying a bucket
Specifying a task (pipeline_tag)
Specifying a license
Evaluation Results
CO2 Emissions
Linking a Paper
Model Card text
FAQ
How are model tags determined?
Can I add custom tags to my model?
How can I indicate that my model is not suitable for all audiences

使用雲端模型的安全考量

- 除了原本地端模型的問題，還有哪些額外問題？
- 最直接的風險就是資料外洩
  - 可以提供哪些資料？
  - 資料傳輸時的加密
- 需要掌握目前 API 呼叫模型的連帶動作
  - 呼叫 API 可以不呼叫其他工具？

高盛分析師和AI討論謀殺前女友！ 遭OpenAI直接通報逮人

2026/08/19 15:20 即時新聞 / 綜合報導



OpenAI示意圖。（路透）

美國佛羅里達州日前發生1起罕見的案件。1名25歲的前高盛（Goldman Sachs）金融分析師達倫（Darren Zhou），因在ChatGPT中詳細記錄並演練強暴、殺害前女友及其家人的計畫，遭開發商OpenAI後台審查團隊主動偵測發現。OpenAI認定其內容具備「即時人身傷害威脅」，隨即向美國聯邦調查局（FBI）通報。警方接獲通報後迅速介入並將其逮捕，法院於近期正式判決。

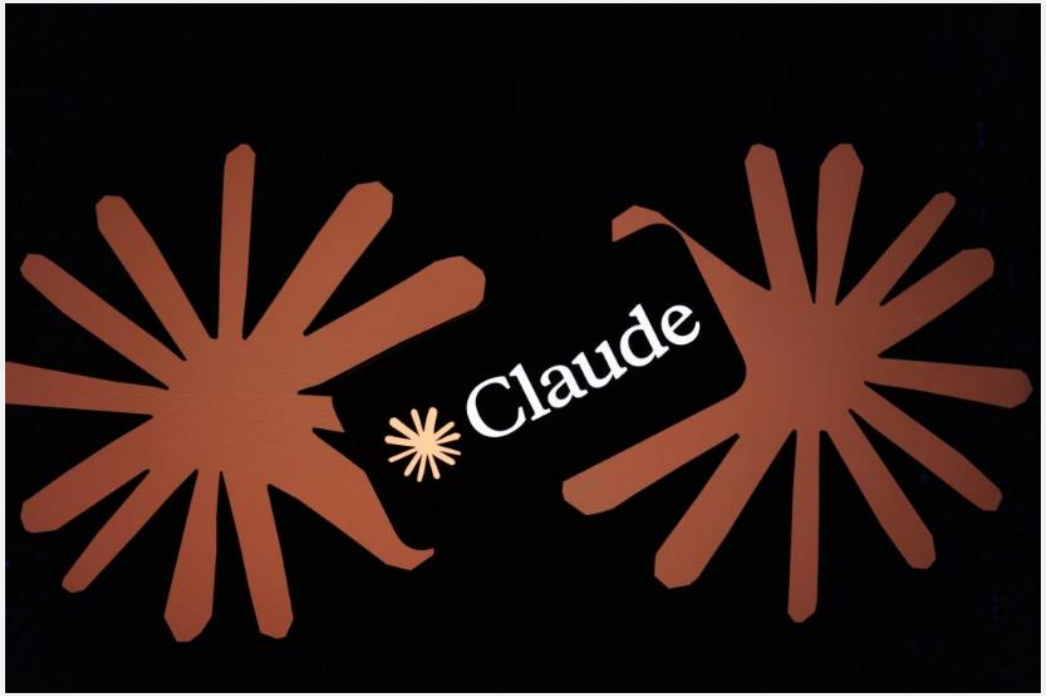
https://news.ltn.com.tw/news/world/breakingnews/5545154

不見得有關係但不能只有我看到

別再把AI當出氣筒！Claude首度禁止用戶亂罵　11月新規上路

2026/10/09 12:30
文 / 記者吳佩樺

加入Google首選



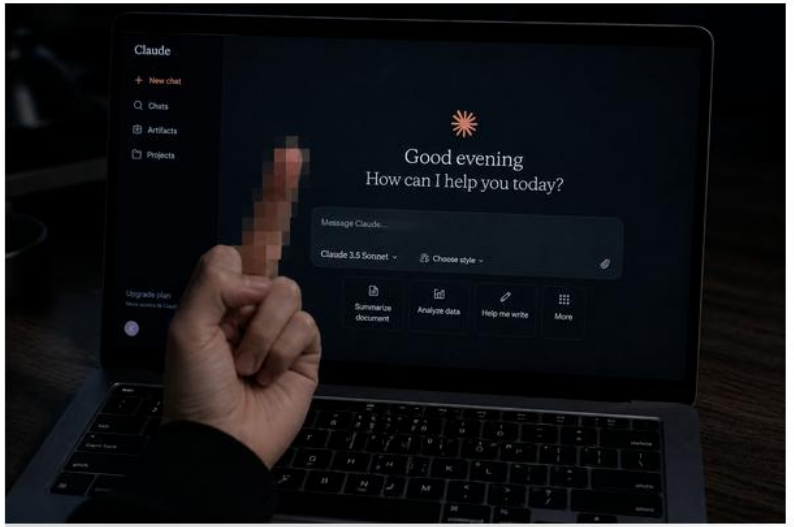
Claude首次明文禁止使用者持續辱罵或惡意對待AI模型，(圖 / 路透社)

https://3c.ltn.com.tw/news/67868

ETtoday新聞雲 > AI科技　2026年09月01日 10:18

AI科技　AI大趨勢　AI生活　數位應用　3C科技

罵Claude一句「fxxk you」就被終止對話？用戶怒退Max訂閱



▲Claude因被罵髒話結束對話引熱議。(AI協作圖／記者吳立言製作，經編輯審核)

記者吳立言／綜合報導

https://www.ettoday.net/news/20260901/3229235.htm

- OpenClaw 架構
- 由本地模型+高限制建立本地代理人應用
- 加入通道可以由 Line 控制
- 逐步放寬與安全風險
  - 工具的限制
  - Skill 的限制
  - Plugin 安全與控制
  - 存取控制機制的不足與限制
  - 執行環境的安全考量

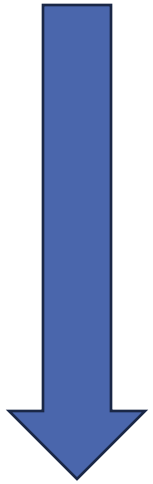
回到之前執行的唯讀政策

- openclaw config set tools.deny `'["exec","process","write","edit","apply_patch","browser","web_fetch","web_search","nodes","cron","gateway"]' `

工具	被禁止的主要動作	開放後的安全風險
exec	執行 Shell、PowerShell 等系統命令	極高：遠端程式碼執行 (RCE)、讀取機密、安裝惡意軟體或修改系統
process	管理與互動執行中的命令工作階段	高：持續操作既有程序、向互動式工作階段送入命令或控制長時間工作
write	建立或覆寫檔案	高：覆寫設定、程式碼、文件或工作資料
edit	修改既有檔案內容	高：植入惡意程式碼、修改應用程式邏輯
apply_patch	使用 Patch 修改檔案	高：批次變更程式碼、植入後門或破壞專案
browser	操作網頁瀏覽器、點擊、輸入、讀取頁面	高：操作已登入網站、提交表單、利用使用者的既有登入權限
web_fetch	透過 HTTP(S) 取得指定網址內容	中：惡意網頁 Prompt Injection、非預期外連、在特定設定下的 SSRF
web_search	使用搜尋服務查詢網路資訊	中：搜尋字詞洩漏敏感資訊、搜尋結果污染、Prompt Injection
nodes	操作已配對的裝置或節點	極高：跨裝置命令執行、螢幕錄製、相機存取等，視節點能力與授權而定
cron	建立、修改與管理排程工作	高：建立持續性惡意排程、定期執行非預期任務
gateway	透過 Gateway 管理介面執行管理操作	極高：更改服務設定、影響 Agent 系統運作及安全政策

以OpenClaw 的 exec 為例來看開放層級

模式	行為	安全考量
deny	禁止執行	最嚴格
allowlist	只允許清單內的命令	適合固定、自動化任務
ask	允許清單內直接執行，其他要求人工核准	適合互動式使用
auto	未命中允許清單時，先由自動審查器評估，必要時交由人工	仍存在自動審查誤判風險
full	不要求一般命令核准	高風險，不宜作為預設值



開放 tool 後可進行的安全控制

控制機制	主要目的	典型作法
Tool Allowlist	限制可使用的工具	只允許 Agent 使用必要的 Tool
Execution Policy	限制工具內可以執行的操作	命令白名單、參數限制、允許的 URL
Sandbox	限制執行環境及影響範圍	容器隔離、檔案系統限制、網路限制
Human Approval	防止未授權的高風險操作	執行前由使用者確認
Resource Access Control	限制能操作哪些資源	RBAC、ABAC、資源及作業層級授權
Monitoring & Auditing	追蹤與偵測異常行為	Tool Call Log、告警、行為追溯

```
PS C:\Users\user> openclaw skills list
|
◇

🦞 OpenClaw 2026.9.8 (fc23bc8) — I autocomplete your thoughts—just slower and with more API calls.

Skills (20/55 ready)
```

Status	Skill	Description	Source
△ needs setup	🔐 1password	Set up and use 1Password CLI for sign-in, desktop integration, and reading or injecting secrets.	openclaw-bundled
✓ ready	📦 add-model-provider	Add and live-prove a model provider with non-interactive config one-liners, without exposing credentials.	openclaw-custodian
△ needs setup	📝 apple-notes	Create, view, edit, delete, search, move, or export Apple Notes via the memo CLI on macOS.	openclaw-bundled
△ needs setup	⏰ apple-reminders	List, add, edit, complete, or delete Apple Reminders and reminder lists via remindctl.	openclaw-bundled
△ needs setup	🐻 bear-notes	Create, search, and manage Bear notes via grizzly CLI.	openclaw-bundled
△ needs setup	📰 blogwatcher	Monitor blogs and RSS/Atom feeds for updates using the blogwatcher CLI.	openclaw-bundled
△ needs setup	🫐 blucli	BluOS CLI (blu) for discovery, playback, grouping, and volume.	openclaw-bundled
✓ ready	📦 browser-automation	Use when controlling web pages with the OpenClaw browser tool, especially multi-step flows, login checks, tab management, or recovery from stale refs/ timeouts.	openclaw-extra

- OpenClaw 架構
- 由本地模型+高限制建立本地代理人應用
- 加入通道可以由 Line 控制
- 逐步放寬與安全風險
  - 工具的限制
  - Skill 的限制
  - Plugin 安全與控制
  - 存取控制機制的不足與限制
  - 執行環境的安全考量

Skill 與 Tool 有什麼不同？

比較項目	Tool	Skill
功能	執行實際操作	指導 Agent 如何完成任務
典型內容	API、函式、系統操作	SKILL.md、腳本、範例
安全風險	工具濫用、未授權操作	惡意指令、供應鏈污染、工作目標劫持
主要控制	Allow/Deny、Sandbox、Approval	Skill 審查、來源驗證、Allowlist
安全邊界	Tool Execution	Skill Loading / Instruction Trust

Tool 決定 Agent 能執行什麼；Skill 影響 Agent 決定要執行什麼。

Skill 的四種主要安全風險

- 惡意 Skill(Malicious Skill)
  - 第三方 SKILL.md 夾帶隱藏指令，誘導 Agent 讀取機密或執行非預期操作。
- Skill 供應鏈攻擊(Supply Chain Attack)
  - Skill 來源遭冒用、內容被竄改，或相依腳本植入惡意程式。
- 工具權限濫用(Tool Privilege Abuse)
  - Skill 利用 Agent 已開放的 exec、browser、write 等工具，執行超出使用者意圖的動作。
- Skill 更新與持續性風險(Skill Persistence)
  - 已安裝 Skill 後續遭惡意更新，或 Agent 自行建立、修改 Skill，改變未來任務的行為。

- 目前的 OpenClaw 支援 Agent 建立及更新自己的 Skills，因此除了第三方安裝風險，也要考慮 Skill 內容在使用過程中發生變更。

Skill 的安全控制機制

控制機制	作法
Skill Allowlist	限制各 Agent 可以載入哪些 Skills
Skill Integrity	確認 Skill 來源、版本與完整性
Skill Security Review	審查 SKILL.md、腳本、相依套件及惡意指令
Skill Lifecycle Control	安裝、更新及修改時進行審核
Tool Permission Enforcement	即使 Skill 要求使用工具，仍必須符合 Tool Policy
Sandbox	限制 Skill 所引用程式的執行環境

- OpenClaw 架構
- 由本地模型+高限制建立本地代理人應用
- 加入通道可以由 Line 控制
- 逐步放寬與安全風險
  - 工具的限制
  - Skill 的限制
  - Plugin 安全與控制
  - 存取控制機制的不足與限制
  - 執行環境的安全考量

Plugin 的安全問題

- Plugin：擴充 OpenClaw Runtime 的程式模組，可新增 Tool、Skill、Channel、Model Provider、Hooks 等功能。
  - 惡意原生 Plugin 可能相當於在 OpenClaw 程序內執行任意程式碼。

安全風險	威脅範例	建議控制
惡意 Plugin(Malicious Plugin)	第三方 Plugin 載入後，直接竊取環境變數或憑證	Plugin Allowlist、程式碼審查
供應鏈攻擊(Supply Chain Attack)	Plugin 更新版本遭植入後門	來源驗證、版本固定、更新審核
過度權限(Excessive Privileges)	Plugin 只需傳送 LINE 訊息，卻能存取不必要的系統資料	最小權限、執行環境隔離
惡意 Hooks(Malicious Hooks)	Plugin 在 Agent 執行前後的生命週期事件中蒐集敏感資訊	Hook 審查、限制 Plugin 載入
敏感資料洩漏(Data Leakage)	Plugin 將對話、Token 或文件傳送到外部服務	Secrets Management、DLP、網路出口限制
Plugin 漏洞(Plugin Vulnerabilities)	Plugin 的 Webhook 或 API 存在漏洞，使攻擊者影響 Gateway	弱點掃描、修補管理、輸入驗證

OpenClaw 既有的 Plugin 安全控制

控制機制	設定	用途
全域 Plugin 開關	plugins.enabled	啟用或停用 Plugin 系統
Plugin Allowlist	plugins.allow	只允許指定 Plugin 載入
Plugin Denylist	plugins.deny	禁止指定 Plugin
個別啟用控制	plugins.entries.<id>.enabled	啟用或停用某個 Plugin
安裝審查政策	security.installPolicy	安裝或更新前進行來源及程式碼政策檢查
同意機制 (Capability Consent)	安裝 / 啟用時的能力審查	檢視 Plugin 宣告的工具、Hooks、權限與其他能力

- OpenClaw 架構
- 由本地模型+高限制建立本地代理人應用
- 加入通道可以由 Line 控制
- 逐步放寬與安全風險
  - 工具的限制
  - Skill 的限制
  - Plugin 安全與控制
  - 存取控制機制的不足與限制
  - 執行環境的安全考量

那要特別做 Access Control 嗎？

- Tool 與 Skill 的限制，只能決定 Agent 具備哪些能力，無法保證每次操作都符合授權。

安全問題	說明	威脅案例
資源存取範圍(Resource Scope)	Agent 可以使用 Tool，不代表能存取所有資源	Agent 具有 read 權限，卻讀取不屬於使用者的機密文件
使用者權限差異(User Authorization)	同一 Agent 可能服務不同權限的使用者	一般員工透過共用 Agent 存取主管資料
操作權限(Operation Authorization)	即使有權存取資源，也不代表能執行所有操作	Agent 可查詢資料，但不應刪除或匯出
跨 Agent 權限擴張(Cross-Agent Privilege Escalation)	Agent 呼叫其他 Agent 時，可能利用其較高權限	低權限 Agent 委派管理 Agent 執行敏感操作
權限委派(Delegated Authorization)	Agent 代表使用者行動時，應受原始授權範圍限制	User A 透過 Agent B 存取原本無權取得的資料

OpenClaw 既有的 Access Control

控制對象	既有安全機制	實際應用範例
User → Gateway	Channel Pairing/ Allowlist	LINE 只允許指定使用者與 OpenClaw 對話，其他使用者無法直接使用
User → Agent	Channel Bindings/ Routing	來自 LINE 的訊息導向 Personal Agent；工作群組訊息導向 Work Agent
Agent → Tool	tools.allow/ tools.deny	Research Agent 可使用 web_search，但不得使用 exec 執行系統命令
Agent → Skill	Agent-specific Skill Allowlist	Document Agent 只能載入 docs-search Skill，不能載入其他 Skills
Agent → Session	tools.sessions.visibility	限制 Agent 只能讀取目前工作階段或其建立的子工作階段，避免讀取其他對話
Agent → Agent	tools.agentToAgent / subagents.allowAgents	Research Agent 可與 Writer Agent 通訊或委派任務，但不得呼叫其他未允許的 Agent

範例與不足之處

```
{
  "agents": {
    "entries": {
      "research": {
        "skills": ["docs-search"],
        "tools": {
          "allow": ["read", "web_search"],
          "deny": ["exec", "write", "edit", "apply_patch"]
        }
      }
    }
  }
}
```

- 這個設定控制兩件事：
  - Agent 只能使用允許的工具。
  - Agent 只能載入指定的 Skill。
- 不能確保 read 只能讀取某位使用者授權的文件。

```
{
  "tools": {
    "sessions": {
      "visibility": "tree"
    }
  }
}
```

- 將 visibility 設為 self，可以限制 Agent 透過 Session Tools 讀取其他對話。
- 不代表完整的多使用者隔離，仍需考慮工作區及憑證等其他存取路徑。

範例與不足之處 (續)

- 假設系統中有 Research、Writer、Finance 三個 Agent，只希望 Research 與 Writer 進行跨 Agent 通訊：

```
{
  "tools": {
    "agentToAgent": {
      "enabled": true,
      "allow": ["research", "writer"]
    }
  }
}
```

```
{
  "agents": {
    "entries": {
      "research": {
        "subagents": {
          "allowAgents": ["writer"]
        }
      }
    }
  }
}
```

- 這是 Gateway 層級的跨 Agent 通訊限制，並不是方向性的「Research 只能呼叫 Writer」授權。

- Research 可委派的目標 Agent 被限制在 Writer，而 Finance 不在其允許清單內。
- 最終做到的是「Research 可以呼叫哪個 Agent？」，而不是「Research 可以要求 Writer 做哪些事？」

Agent Access Control 需要補強的機制

有那麼嚴重？

- OpenClaw 原生權限設定之外，企業級 Agent 系統還需要實作的授權能力。
- 核心就是 Granularity 問題

額外控制機制	主要目的	實作技術
Agent Identity & Authentication	確認 Agent 身分，防止其他 Agent 偽冒	Agent Identity、SPIFFE / SPIRE、mTLS
Resource-Level Authorization	限制 Agent 可以存取哪些文件、資料庫及 API 資源	RBAC、ABAC、ReBAC
Operation-Level Authorization	限制 Agent 對資源可以執行哪些作業	API Scope、細粒度權限、OPA
Delegated Authorization	確保 Agent 代表使用者或其他 Agent 行動時，不超過被委派的權限	OAuth 2.0 Token Exchange、Scoped Token
Context-Aware Authorization	根據任務、資料敏感度、環境與風險動態調整授權	ABAC、Risk-Adaptive Access Control

Agent 相互溝通情境與風險

情境	Agent 身分偽冒風險
單一 Gateway、單一使用者	相對低
單一 Gateway、多個 Agent	相對低，但需防止 Session 混淆及設定遭竄改
單一 Gateway、多個互不信任的使用者	較高
跨 Gateway / A2A	高度重要

比較	同 Gateway Agent-to-Agent	跨 Gateway A2A
通訊機制	OpenClaw Session Tools	A2A Protocol
身分識別	Gateway 管理的 Agent ID	外部 Peer 身分與認證憑證
存取控制	tools.agentToAgent、Session Visibility	A2A Peer Authentication、Channel Policy
信任邊界	同一 Gateway 信任域內	跨 Gateway / 跨系統信任邊界
主要風險	跨 Agent 工作階段存取、權限濫用	外部 Agent 偽冒、未授權委派、跨組織資料外洩

- OpenClaw 架構
- 由本地模型+高限制建立本地代理人應用
- 加入通道可以由 Line 控制
- 逐步放寬與安全風險
  - 工具的限制
  - Skill 的限制
  - Plugin 安全與控制
  - 存取控制機制的不足與限制
  - 執行環境的安全考量

Agent Runtime 的安全機制

防護類別	主要防護內容	威脅範例	代表技術
環境安全與組態強化 (Environment Security & Hardening)	強化主機、網路、Gateway、容器及服務組態，進行弱點與修補管理	Gateway 對外暴露、管理介面弱驗證、系統元件漏洞	CIS Benchmarks、Vulnerability Scanning、Configuration Audit
執行隔離(Execution Isolation)	限制 Agent 執行時可使用的系統資源、檔案及網路，降低攻擊影響範圍	Agent 執行惡意命令，嘗試讀取主機機密或感染其他容器	Docker、gVisor、Firecracker
輸入與輸出安全防護 (Input & Output Protection)	檢查使用者輸入、RAG 文件、Tool Response 及 Agent 輸出，偵測惡意指令與敏感資訊	外部文件夾帶 Prompt Injection，誘導 Agent 洩漏機密資訊	LLM Guardrails、Prompt Injection Detection、DLP
Agent 行為監控與威脅回應 (Agent Behavioral Monitoring & Response)	監控 Agent 的執行軌跡、工具呼叫序列、跨 Agent 互動及目標偏離，偵測異常並採取回應	Agent 原本只需產生報告，卻持續存取無關資料或反覆呼叫其他 Agent	Agent Tracing、Anomaly Detection、SIEM、SOAR

環境安全強化的原則

- 安全基線 (Security Baseline)： 使用最小權限設定，停用不必要的服務、介面與功能。
- 網路安全 (Network Security)： Gateway 優先綁定 localhost，透過 Firewall、VPN 或安全反向代理限制外部存取。
- 身分與組態安全 (Identity & Configuration Security)： 強化管理身分鑑別、管理介面存取及組態檔權限。
- 弱點與修補管理 (Vulnerability & Patch Management)： 持續更新 OpenClaw、Plugins、容器映像檔及相依套件。
- 供應鏈安全 (Supply Chain Security)： 驗證模型、Skills、Plugins 與軟體套件的來源、版本及完整性。
- 安全組態稽核 (Security Configuration Audit)： 定期執行組態檢查、偵測不安全設定及組態漂移。

謝謝各位的聆聽

